Privacy and security note: Project Udyam Digital

Team Shankhnad, MMMUT Gorakhpur. Airtel SYNC 2026, Enterprise Track A. November 2026. Covers the prototype in this repository.

Prototype on the competition's synthetic data. Accel Business is the case study's fictional operator. This note describes how the system is designed and what is implemented; it is not legal advice and not a claim of compliance or certification. Counsel must review it before launch.

1. What personal data the journey uses, why, and for how long

Data	Purpose	How it is held	Kept for
Mobile number	OTP login; call-backs the owner asks for	Keyed hash for lookup; encrypted copy that sales can reveal only for a requested call (audited)	Life of the account
Business profile	Advice, eligibility, price	Database; GSTIN and Udyam masked in every screen, API response and log line	12 months after last activity (policy; not yet automated)
KYC documents	Verify the business, signatory and address before activation	File signature, size and pixel checks; re-encoded to strip metadata; encrypted at rest; every view audited	180 days after activation; 30 days after rejection or cancellation; 180 days if abandoned; at once on withdrawal (automated)
Verification result	Record of the check, as licence conditions require	Decision, reasons and masked identifiers; no images	Period set by telecom licence conditions (to confirm with Legal)
Consent records	Proof of consent and withdrawal	Purpose, notice version, language, time; withdrawals timestamped	Life of the account plus the limitation period (to confirm)
Audit log	Accountability, investigation	Who did what and when; identifiers scrubbed before writing	1 year (policy)

2. DPDP Act 2023 and DPDP Rules 2025: when each duty applies and what we built

Duty	Applies	In the prototype	Before launch
Notice (s.5; Rule 3)	**13-14 May 2027**	Itemised per purpose: data, reason, recipients, retention, rights, grievance contact; Hindi and English; versioned	Legal review; more languages
Consent (s.6)	**13-14 May 2027**	KYC consent required before any upload; optional purposes off by default; withdrawal as easy as giving, from "My privacy"	Consent Manager link optional (Rule 4 from Nov 2026)
Purpose limits, minimisation	**13-14 May 2027**	Registry lookups send only the GSTIN or Udyam number; an LLM, if configured, gets masked text only, never documents	Data processing agreements with every vendor
Security safeguards (s.8(5); Rule 6)	**13-14 May 2027**	Encryption at rest, 5 roles with partner scoping, audit trail, rate limits, upload hardening, masked logs; production will not start without its keys	Keys in a KMS, staff SSO with MFA, penetration test, monitoring
Breach intimation (s.8(6); Rule 7)	**13-14 May 2027**	Audit trail and document-view log support investigation	Incident runbook: Board and affected users without delay, detailed report within 72 hours
Erasure (s.8(7); Rule 8)	**13-14 May 2027**	Deletion dates per the notice; purge at start-up and via an admin job	Daily scheduler; erasure-on-request workflow
Rights (s.11-14)	**13-14 May 2027**	"My privacy": data summary, consents, withdrawal; grievance contact in the notice	Correction and erasure requests with an SLA; nominee
Board and definitions (Rules 1, 2, 17-21)	**in force since Nov 2025**	No direct product duty; the design anticipates the duties above so nothing needs rework in May 2027.	

3. Integrations: what is mocked, what production needs

Capability	Prototype	Production route
GSTIN	MOCK local registry from synthetic CSV	Licensed GST Suvidha Provider (GSTN search)
Udyam	MOCK local registry	Authorised data source or aggregator; no official public API found
DigiLocker, Entity Locker	Not built	Requester access via API Setu (approval needed)
eSign	Not built	CCA-empanelled eSign Service Provider
OTP	Shown on screen (demo)	SMS gateway with DLT-registered template
Payments	Simulated, with failure path	Payment gateway, UPI AutoPay mandate

No government website is scraped; mocks share the production adapters' interface.

4. Telecom KYC and decisions about people

- DoT business connections: each end user of a business mobile line completes their own KYC before the SIM is activated; the tracker shows this step. The prototype does not perform end-user KYC.
- No automatic rejection: unclear or conflicting documents go to a KYC reviewer, who records a reason. OCR and models never approve or reject alone.
- The lead score only orders call queues; it never changes price, eligibility or KYC. Capacity is reserved for non-GST micro businesses the model ranks low.

5. Open items before launch

- Data protection impact review; vendor DPAs; data residency in India
- KMS-managed keys and rotation; SSO with MFA; VAPT
- Automated purge for leads and audit log; correction and erasure workflow
- Re-measure OCR and fraud checks on real phone photos

Dates: DPDP Rules 2025 notified 13-14 Nov 2025 (Rules 1, 2, 17-21 at once; Rule 4 after one year; Rules 3, 5-16, 22-23 after 18 months; Mondaq, PIB). DoT business connections: Aug 2023, May 2024. Code: backend/app/consent.py, retention.py, security.py, kyc/.